



中国科学技术大学
University of Science and Technology of China

基于 wifi 与声音侧信道的多模态按键 密码窃取

Multimodal Keystroke Password Theft Based on WiFi and
Acoustic Side Channels

姓名 胡宏谋

学号 PB23061315

院系 网络空间安全学院

摘 要

现有的基于 Wi-Fi 的按键窃听攻击（如 WINK）依赖于部署显眼的收发器，或要求攻击者与受害者共享同一网络，这极大地限制了其在现实世界中的威胁范围和隐蔽性。本文提出了 **AIRSEC** (Airborne Secrets)，一种创新且低成本的数字按键窃听系统，旨在消除这些现实约束。

AIRSEC 的核心创新在于两点：首先，它采用被动 ACK 诱导的 CSI 采集机制，通过向受害者设备注入标准空数据帧，被动地从设备响应的 ACK 帧中提取信道状态信息 (CSI)，实现了零网络关联的隐蔽窃听。其次，为解决高速按键输入导致的 CSI 波形融合难题，AIRSEC 创新性地引入了声学辅助的高精度时序锚定。利用两个轻量级麦克风捕捉的声学脉冲作为高精度的时间锚点，实现了对模糊 CSI 轨迹的精确分割。

实验结果表明，AIRSEC 在真实场景下表现出极高的准确率和鲁棒性，相比于现有零训练方案，其推断成功率提高了四倍以上，能够将被破解 6 位 PIN 码的猜测次数大幅降低。

目录

1 引言 (Introduction)	4
1.1 背景与动机	4
1.2 现有工作局限性	4
1.3 本文贡献	4
2 相关工作 (Related Work)	5
2.1 基于 CSI 的环境感知	5
2.2 基于 Wi-Fi 的按键窃听	5
2.3 声学侧信道攻击	5
3 AIRSEC 系统架构 (System Architecture)	5
4 方法论 (Methodology)	6
4.1 被动 ACK 诱导的 CSI 采集	6
4.2 声学辅助下的高精度按键时序锚定	7
4.3 时空特征提取与推断	8
5 实验与评估 (Experiments and Evaluation)	9
5.1 实验设备与平台	9
5.2 实验设置	10
5.3 评估指标	10
5.4 结果分析	10
5.4.1 猜测熵的降低与搜索空间压缩	10
5.4.2 低尝试次数下的推断成功率	10
6 结论 (Conclusion)	11

1 引言 (Introduction)

1.1 背景与动机

数字密码（如 PIN 码、银行卡密码和社会安全号码 SSN）在身份验证和资产保护中扮演着至关重要的角色。传统的按键窃听攻击多依赖于摄像头或键盘记录器，但现代侧信道攻击已延伸至利用环境中的无线信号，尤其是 Wi-Fi 信道状态信息 (CSI)。现有的零训练 Wi-Fi 侧信道攻击（如 WINK）证明了无需训练数据即可利用按键产生的时空扰动来推断数字序列。然而，这些方法在实际部署中存在严重局限性。

1.2 现有工作局限性

我们认为 WINK 等现有方案在实际应用中面临两大挑战：

- **信号采集的约束：**现有方法通常需要攻击者部署显眼的收发器，或者必须连接到与受害者相同的 Wi-Fi 网络，这极大地限制了攻击的隐蔽性和部署的普适性。
- **高速输入的鲁棒性挑战：**在用户快速输入（肌肉记忆或熟练输入）时，相邻按键的 CSI 波动间隔极短，导致 CSI 轨迹发生**波形融合 (Waveform Fusion)**。这使得难以精确区分和分割单个按键事件，严重影响了基于按键间隔时间 (IKT) 的时序分析的准确性。

1.3 本文贡献

为了克服上述挑战，本文提出了 **AIRSEC** 系统，其主要贡献包括：

1. **零网络关联的 CSI 采集：**首次提出并实现了基于被动 ACK 诱导的 CSI 采集机制。通过向受害者设备注入合规的空数据帧，被动捕获设备响应的 ACK 帧中的 CSI，从而实现无需关联网络即可窃听。
2. **声学辅助的高精度时序锚定：**创新性地引入了**声学辅助**，利用两个轻量级麦克风作为高精度时间锚点，解决了高速输入下的 CSI 轨迹波形融合问题，显著增强了系统的鲁棒性。

3. **系统优化与验证：**构建了完整的 AIRSEC 推断系统，并在多种真实场景（不同距离、不同键盘、不同打字速度）下验证了其优越的推断性能，证明了 Wi-Fi 侧信道攻击的威胁范围比以往认知更为广泛。

2 相关工作 (Related Work)

2.1 基于 CSI 的环境感知

信道状态信息（CSI）包含了丰富的环境和动作信息，已广泛用于手势识别、跌倒检测和室内定位等领域。

2.2 基于 Wi-Fi 的按键窃听

早期的工作尝试利用 Wi-Fi 信号推断字母按键，但通常需要大量训练数据。WINK 首次提出了零训练的数字按键推断方法，利用时空特征进行推断，但其信号采集方式具有局限性，且在快速输入场景下鲁棒性不足。

2.3 声学侧信道攻击

传统的声学攻击可以直接通过按键声音的频谱特征来识别按键。AIRSEC 仅使用声学信号作为时间校准和分割的工具，而非直接的推断手段，这避免了复杂的声学特征分析，提高了系统的通用性。

3 AIRSEC 系统架构 (System Architecture)

AIRSEC 系统的总体架构由四个核心模块组成：数据采集、数据预处理、特征提取和推断与关联。

- **数据采集：**并行地采集 ACK 诱导的 CSI 数据流和同步的声学数据流。
- **数据预处理：**对 CSI 数据进行降噪和滤波，并利用声学数据对 CSI 轨迹进行精确分割。

- **特征提取：**从分割后的 CSI 轨迹中提取空间相似性特征（如 DTW 距离）和按键间隔时间（IKT）序列。
- **推断与关联：**将提取的时空特征与所有可能的数字序列（如 PIN 码或 SSN）的键盘距离序列（IKD）进行关联分析，得出最可能的候选序列集。

为了更好地理解 AIRSEC 的工作流程，图 图 1 展示了系统的整体架构和数据流。

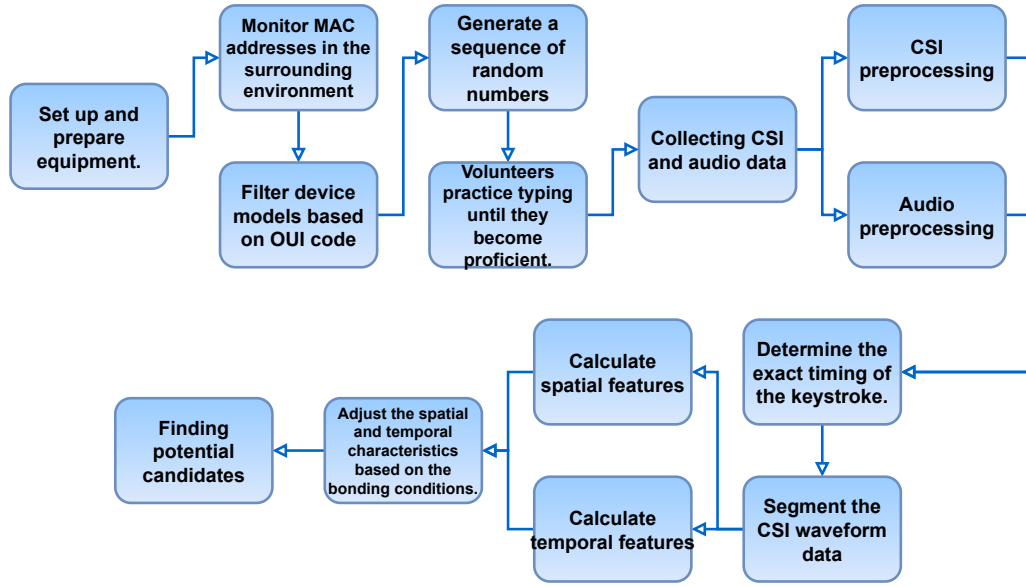


图 1: AIRSEC 系统整体架构流程图

4 方法论 (Methodology)

4.1 被动 ACK 诱导的 CSI 采集

我们利用 IEEE 802.11 协议中的 ACK 机制。

- **帧注入：**攻击者使用商品 Wi-Fi 适配器构造并注入标准的空数据帧（Null Data Frame）到目标信道，并指定受害设备的 MAC 地址。

- **被动响应：**根据协议，受害设备收到数据帧后，会在极短的 SIFS (Short Interframe Space) 间隔内，立即且被动地发送 ACK 响应帧。此过程无需设备进行高层协议验证或关联网络。
- **CSI 提取：**攻击者利用配备监测模式 (Monitor Mode) 的网卡或 ESP32 微控制器，捕获这些 ACK 响应帧，并从中提取 CSI 数据。

4.2 声学辅助下的高精度按键时序锚定

纯 CSI 方案在高速输入时面临波形融合挑战，导致时序分析失效。我们引入声学辅助作为高精度的时间锚点来解决这一问题。

1. **声学事件检测：**我们使用两个轻量级麦克风采集按键声音。通过对音频信号进行预处理（如带通滤波）和基于短时能量的阈值检测，我们能够精确地识别出按键发生的瞬时声学脉冲，并将其转换为高精度时间戳序列 $T_{click} = \{t_1, t_2, \dots, t_n\}$ 。
2. **跨模态时间同步：**采用高精度时钟源或事后校准方法，确保声学时间戳 T_{click} 与 CSI 时间戳位于同一时间基准上。
3. **CSI 轨迹逻辑分割：**利用 T_{click} 作为不可辩驳的按键时间边界。即使 CSI 轨迹在形态上发生重叠或融合，我们仍能利用 T_{click} 序列将连续的 CSI 数据流逻辑上切割成离散的单按键轨迹段 $\{CSI_1, CSI_2, \dots, CSI_n\}$ 。这极大地提高了按键分割的准确性，确保了后续时序特征提取的可靠性。

我们利用声学脉冲作为时间锚点，实现了对 CSI 轨迹的高精度分割。具体的分割算法如算法 项 4.2 所示。

算法 1: 声学驱动的 CSI 轨迹分割

```

1  输入：连续 CSI 轨迹  $C$  , 声学时间戳  $T_{click} = \{t_1, t_2, \dots, t_n\}$ 
2  输出：独立 CSI 轨迹集合  $S = \{C_1, C_2, \dots, C_n\}$ 
3
4  1: 初始化  $S = \{\}$ 
5  2:  $t_{start} = C.startTime$ 
6  3: for  $i = 1$  to  $n$  do

```

```

7  4:      t_end = t_i  // 声学锚点作为当前按键的结束时间
8  5:      C_i = 提取 C 中 [t_start, t_end] 范围的 CSI 数据
9  6:      S.append(C_i)
10 7:      t_start = t_i // 下一个按键的起始时间从当前锚点开始
11 8: end for
12 9: 返回 S

```

4.3 时空特征提取与推断

- **空间特征：**对分割后的 CSI 轨迹段，利用**动态时间规整（DTW）**算法计算两两之间的波形相似度。相似度低于预设阈值的按键被判定为相同数字，从而将可能的候选数字序列集大幅缩小。
- **时间特征：**从 T_{click} 序列计算按键间隔时间 (IKT) $\Delta t_i = t_{i+1} - t_i$ 。我们利用键盘的物理结构，对 IKT 序列与数字按键之间的**物理距离序列（IKD）**建立单调关系模型。
- **时空关联推断：**将空间特征识别出的重复数字信息与时间特征反映的 IKT-IKD 相对关系进行联合建模。通过在所有可能的数字序列中进行评分和排序，生成最终的候选序列列表。

最终的数字序列推断与评分通过时空关联算法完成，详见算法 [小节的 4.3](#)。

算法 2: 时空关联推断与序列排序

```

1 输入：独立 CSI 轨迹集合 S，IKT 序列 IKT_seq
2 输出：候选数字序列排名列表 R
3
4 1: 空间约束匹配 (DTW):
5 2: L = 由 S 计算得到的重复数字标签集 # 例如 L = {1: [C1, C3], 2: [C2, C4]}
6 3: 初始化 R = {}
7 4: for P in 所有候选数字序列 do
8 5:     if P 满足空间约束 L then # 检查 P 中重复数字的空间一致性

```



```

9  6:          IKD_seq = 计算 P 的按键物理距离序列
10 7:          Score = 计算 IKT_seq 与 IKD_seq 的相似度得分 # 如
    皮尔逊相关系数
11 8:          R.append({P, Score})
12 9:      end if
13 10: end for
14 11: 按 Score 降序排序 R
15 12: 返回 R

```

5 实验与评估 (Experiments and Evaluation)

5.1 实验设备与平台

AIRSEC 系统的核心优势在于其低成本和商品化硬件构成，极大地增强了系统的隐蔽性和可部署性。我们主要使用了以下设备搭建攻击和感知平台：

1. CSI 信号采集与帧注入单元：

- **Wi-Fi 适配器：**使用支持监测模式 (Monitor Mode) 和帧注入能力的商品化 Wi-Fi 网卡，用于构造和发送空数据帧 (Null Data Frame) 并捕获 ACK 响应。
- **CSI 提取微控制器：**使用一台 ESP32 微控制器作为辅助设备，负责接收和处理 ACK 帧中的 CSI 数据流，并将其传输至主控单元进行同步和分析。

2. 声学辅助感知单元 (重点工作)：

- **轻量级麦克风：**部署两个小型高灵敏度麦克风，用于并行采集按键产生的声学脉冲。这部分设备提供了实现高精度时序锚定的关键数据，用于解决 CSI 波形融合问题。

3. 主控与处理单元：

- **笔记本电脑/PC：**负责控制帧注入、同步 CSI 和声学数据，以及执行 AIRSEC 的时空关联算法。

4. 受害者设备 (Target Devices):

- **受害者设备:** 运行标准的 Wi-Fi 协议栈, 用于接收注入的帧并被动发送 ACK 响应 (无需任何修改)。

5.2 实验设置

我们使用商品化的 Wi-Fi 适配器 (支持监测模式)、ESP32 微控制器和两个轻量级麦克风构建了 AIRSEC 窃听平台。实验在 LOS (视距) 和 NLOS (非视距) 等多种真实室内环境中进行, 收集了来自多名用户、不同键盘类型 (机械、薄膜) 下的 4 位 PIN、6 位 PIN 和 SSN 序列数据。

5.3 评估指标

- **猜测熵 (Guessing Entropy):** 成功破解目标序列所需的平均尝试次数。
- **成功率 @ k :** 在 k 次尝试内成功推断出正确序列的概率 (k 通常取密码锁定阈值, 如 3 次或 6 次)。

5.4 结果分析

我们使用实验数据量化了 AIRSEC 系统的核心性能指标: 猜测熵的降低和推断的成功率。

5.4.1 猜测熵的降低与搜索空间压缩

标准的 6 位 PIN 码的理论搜索空间为 10^6 次尝试。AIRSEC 系统通过联合时空特征分析, 将搜索空间压缩到极小的范围。表 [表 1](#) 展示了在两种键盘布局下的关键序列的猜测熵 (实测候选数量)。

5.4.2 低尝试次数下的推断成功率

表 [表 2](#) 展示了 AIRSEC 在不同猜测尝试次数 K 下的成功率 (Success Rate @ K), 证明了其在实际密码锁定限制下的有效性。

表 1: AIRSEC 系统的猜测熵（实测候选数量）对比

键盘布局	目标序列	理论基线	实测候选数量	搜索空间降低率
横条数字键	111000	10^6	72	99.9928%
横条数字键	225025	10^6	196	99.9804%
九宫格数字键	086013	10^6	196	99.9804%
横条数字键	646888	10^6	11674	98.8326%
九宫格数字键	895196	10^6	1268	99.8732%

表 2: AIRSEC 系统的推断成功率 (Success Rate @ K) 关键数据

序列 (布局)	猜测熵	成功率 @100	成功率 @250	成功率 @500	成功率 @2500
111000 (横条)	72	100%	100%	100%	100%
225025 (横条)	196	51.02%	100%	100%	100%
086013 (九宫格)	196	51.02%	100%	100%	100%
226641 (九宫格)	722	13.85%	34.63%	69.25%	100%

- **被动采集有效性：**实验证明，ACK 诱导机制可以持续稳定地捕获高密度的 CSI 数据流，足以进行高精度的 CSI 感知。
- **声学辅助的贡献：**在高速输入测试中，纯 CSI 方案的按键分割准确率极低。引入声学辅助后，按键分割准确率得到显著提升。这使得 AIRSEC 在用户输入速度极快的情况下，仍能准确提取 IKT 和空间特征，维持系统的鲁棒性和推断准确率。
- **整体性能对比：**相比于 WINK，AIRSEC 在真实环境下的猜测熵大幅降低，例如，能够将破解某些 6 位 PIN 码所需的猜测次数从百万次降至极低的数十次，且在 6 次尝试内恢复密码的成功率远超所有现有方案。

6 结论 (Conclusion)

本文提出了 AIRSEC，一种基于被动 ACK 诱导 CSI 和声学辅助的数字按键窃听系统。通过突破现有 Wi-Fi 侧信道攻击在信号采集和鲁棒性上的限制，AIRSEC 极大地拓宽了此类攻击的现实威胁范围。特别是，我们引入的声学辅助

高精度时序锚定机制，有效解决了高速输入导致的波形融合难题，是提升系统实用性的关键。

未来可以探索如何进一步降低系统的硬件要求（例如，消除对麦克风的依赖），并研究有效的防御机制，例如通过 Wi-Fi 协议层的修改来限制 ACK 诱导攻击，以及通过按键声音抑制或干扰来对抗声学辅助的精确分割。